

**НЕКОММЕРЧЕСКОЕ АКЦИОНЕРНОЕ ОБЩЕСТВО
«КАЗАХСКИЙ НАЦИОНАЛЬНЫЙ ПЕДАГОГИЧЕСКИЙ
УНИВЕРСИТЕТ ИМЕНИ АБАЯ»**



УТВЕРЖДЕНО

Решением Правления

НАО «Казахский национальный
педагогический университет
имени Абая»

от «15» сентября 2025 года

Протокол №

Председатель Правления - Ректор
Тілеп Б.А.



**Каталог угроз и рисков информационной безопасности
Некоммерческого акционерного общества «Казахский национальный
педагогический университет имени Абая»**

Оглавление

1 Общие положения.....	3
2 Нормативная основа	3
3 Классификация угроз.....	3
4 Перечень угроз и рисков.....	5
5 Обновление и актуализация Каталога.....	6
6 Ответственность.	7
Лист согласования.....	8

1 Общие положения

1.1 Настоящий документ – «Каталог угроз и рисков по информационной безопасности» – Некоммерческого акционерного общества «Казахский национальный педагогический университет имени Абая» (далее — Университет) разработаны в соответствии с требованиями законодательства и стандартов Республики Казахстан в области информационной безопасности.

1.2 Целью настоящего документа является создание регламентированной процедуры действий по идентификации, классификации и управлению угрозами и рисками, связанными с обеспечением информационной безопасности, с учетом установленных стандартов, нормативных требований РК и внутренних регламентов университета.

1.3 В настоящих Правилах используются следующие основные термины и сокращения:

ИТ-инфраструктура – совокупность информационных технологий, аппаратных и программных средств, сетевых ресурсов и процессов, которые обеспечивают функционирование и поддержку информационных систем университета;

ИБ – Информационная безопасность;

ПО – программное обеспечение;

ОС – Операционная система;

Администратор - сотрудник, отвечающий за настройку, оптимизацию и обслуживание ИТ-инфраструктуры университета;

Пользователь – Пользователь информационной системы;

Угроза - Вероятность наступления ситуации или действия, способного спровоцировать утечку данных, повреждение их структуры или ограничение доступа к ним, а также негативно повлиять на работу информационных систем и инфраструктуры.

2 Нормативная основа

Настоящий документ разработан в соответствии со следующими нормативно-правовыми актами и документами:

- Постановление Правительства Республики Казахстан от 20.12.2016г. №832 «Об утверждении единых требований в области информационно-коммуникационных технологий и обеспечения информационной безопасности»;

3 Классификация угроз

3.1 Угрозы информационной безопасности подразделяются на следующие основные категории:

- Технические угрозы – связаны с уязвимостями и сбоями оборудования, программного обеспечения и сетевой инфраструктуры,

включая неисправности серверов, ошибки конфигурации сетевых устройств и некорректные обновления;

- Организационные угрозы – обусловлены недостатками в процессах управления, политики и процедур обеспечения ИБ, что включает отсутствие четких регламентов и слабый контроль исполнения;

- Физические угрозы – вызваны воздействием внешних факторов, таких как пожар, затопление, вандализм и кража оборудования. Особое внимание уделяется защите серверных помещений и транспортировки оборудования;

- Человеческие угрозы – включают ошибки персонала, преднамеренные действия злоумышленников и недостаточный уровень подготовки сотрудников.

3.2 Угрозы классифицируются по степени воздействия на:

- Конфиденциальность информации — предотвращение утечки данных к неавторизованным лицам;

- Целостность информации — защита от модификаций, которые могут привести к утрате ее достоверности;

- Доступность информации — обеспечение постоянного доступа к данным и ИТ-ресурсам.

3.3 По вероятности реализации угрозы подразделяются на:

- Высоковоероятные – угрозы, которые могут реализоваться при текущих условиях без значительных усилий злоумышленников или ошибок;

- Средней вероятности – ситуации, которые требуют дополнительных факторов или обстоятельств для возникновения;

- Маловероятные – проблемы, не оказывающие существенного влияния на общую работу ИТ-инфраструктуры.

3.4 По масштабам последствий угрозы классифицируются на:

- Критические – полный отказ работы ключевых систем или значительная утрата данных, влияющая на весь университет;

- Значительные – частичная потеря функциональности или доступности систем, влияющая на отдельные подразделения;

- Незначительные – проблемы, не оказывающие существенного влияния на общую работу ИТ-инфраструктуры;

3.5 По тяжести нарушения:

- Незначительные – небольшие ошибки или сбои, не оказывающие значительного влияния на работу системы и поддающиеся быстрой коррекции;

- Существенные – инциденты, вызывающие временные перебои в работе систем, требующие вмешательства специалистов для устранения последствий;

- Критические – серьезные нарушения, приводящие к утрате данных, длительному отказу в обслуживании или другим катастрофическим последствиям, включая природные и техногенные катастрофы.

3.6 По предвидению последствий нарушителем:

- Намеренные – целенаправленные действия злоумышленников, таких как хакерские атаки, саботаж или шпионаж;

- Ненамеренные – ошибки сотрудников, случайные сбои в работе оборудования или программного обеспечения, вызванные недостаточной квалификацией или человеческим фактором.

3.7 По мотивации:

- Злонамеренные – атаки, направленные на нанесение ущерба университету, включая кибератаки, промышленный шпионаж, мошенничество;

- Незлонамеренные – угрозы, вызванные неосторожностью, неосведомленностью или несоблюдением правил безопасности пользователями или сотрудниками университета.

3.8 По месту возникновения:

- Внешние – атаки со стороны злоумышленников, конкурентов или иных субъектов, не имеющих прямого доступа к информационной системе университета;

- Внутренние – угрозы, исходящие от сотрудников, подрядчиков или других лиц, имеющих доступ к внутренним ресурсам университета.

3.9 По законченности:

- Реализованные – атаки или инциденты, которые уже привели к нарушению работы системы, утечке данных или другим последствиям;

- Нереализованные – потенциальные угрозы, которые могут возникнуть при определенных условиях, но пока не были осуществлены.

3.10 По объекту воздействия:

- Комплексные – угрозы, направленные на всю информационную систему университета, включая инфраструктуру, базы данных, сети и пользователей;

- Локальные – угрозы, влияющие на отдельные компоненты системы, такие как серверы, рабочие станции, конкретные приложения или учетные записи пользователей.

4 Перечень угроз и рисков

4.1 Технические угрозы:

- Сбой оборудования – отказ аппаратных компонентов из-за износа, дефектов производства или неправильной эксплуатации;

- Уязвимости ПО и ОС – недостатки в исходном коде, позволяющие осуществлять несанкционированный доступ или модификацию данных;

- Несанкционированный доступ к сетям – взлом сетевых устройств через уязвимости в протоколах или конфигурациях;

- Сетевые сбои – потеря доступности ресурсов из-за конфигурационных ошибок;

- Сетевые атаки – DDoS, MITM, SQL-инъекции и другие виды атак на целостность и доступность системы.

- Неисправность резервных систем – недоступность данных при необходимости их восстановления;

- Нарушения в системе обновлений – отказ или неправильное применение патчей безопасности;

- ненадежное шифрование данных – возможность перехвата и расшифровки информации.

4.2 Организационные угрозы:

- Неэффективный мониторинг – неспособность своевременно обнаружить и предотвратить инциденты;

- Низкая координация – несогласованность между подразделениями в вопросах реагирования на угрозы.

- Низкий уровень осведомленности персонала – неподготовленность сотрудников к действиям в условиях угроз.

- Пробелы в планировании восстановления – невозможность оперативного реагирования на инциденты;

- Недостаточная отчетность – отсутствие информации для анализа и устранения инцидентов;

- Отсутствие четкой политики ИБ – недостаток инструкций по обеспечению защиты данных.

4.3 Физические угрозы:

- Незащищенные помещения – отсутствие контроля доступа к критическим объектам;

- Кража оборудования – утрата серверов, ноутбуков или других устройств, содержащих конфиденциальные данные;

- Повреждение помещений – пожар, затопление, вандализм и другие возможные риски влияющие на сохранность инфраструктуры;

- Перебои энергоснабжения – риски, связанные с внезапными отключениями электричества.

- Нарушение целостности кабелей – обрывы, вызванные внешними воздействиями.

4.4 Человеческие угрозы:

- Ошибки персонала – некорректная настройка систем, преднамеренная или непреднамеренная утрата данных

- Вредоносные действия сотрудников – инсайдерская угроза, умышленное нарушение безопасности;

- Социальная инженерия – обман сотрудников с целью получения конфиденциальной информации.

5 Обновление и актуализация Каталога

5.1 Каталог подлежит пересмотру и актуализации не реже одного раза в год, а также при:

- Внедрении новых технологий или изменений в инфраструктуре;
- Изменении законодательства в области информационной безопасности;
- Выявлении новых угроз в ходе мониторинга и аудита.

6 Ответственность

- Офицер информационной безопасности – осуществляет общий контроль за соблюдением мер информационной безопасности, включая регулярный аудит выполнения требований и актуализацию нормативной базы;

- Руководитель управления ИТ – координирует действия подразделений и сотрудников в части реализации задач, предусмотренных настоящим Каталогом, включая контроль за соблюдением сроков и полнотой выполнения работ;

- Системные администраторы – обеспечивают техническую реализацию мероприятий по защите информации, включая настройку оборудования, администрирование систем и устранение технических уязвимостей.

ЛИСТ ОЗНАКОМЛЕНИЯ

[illegible]

Алматы, 2025